The Dukes

An espionage operation

Artturi Lehtiö (@lehtior2)

F-Secure

(APT29) The Dukes

An espionage operation

Artturi Lehtiö (@lehtior2)

F-Secure

THE DUKES

Mikko Hypponen
@mikko

Following

Man, we TOTALLY forgot to make a logo for #OnionDuke (f-secure.com/weblog/archive…) - but here we go!

“The Dukes”
are “an advanced
threat actor”

“The Dukes”
are “an advanced
persistent threat”

“The Dukes” perform espionage

“Mini-, Cosmic-, Onion-, Cozy-, …” are toolsets

The 9 toolsets

“Infostealer toolsets”

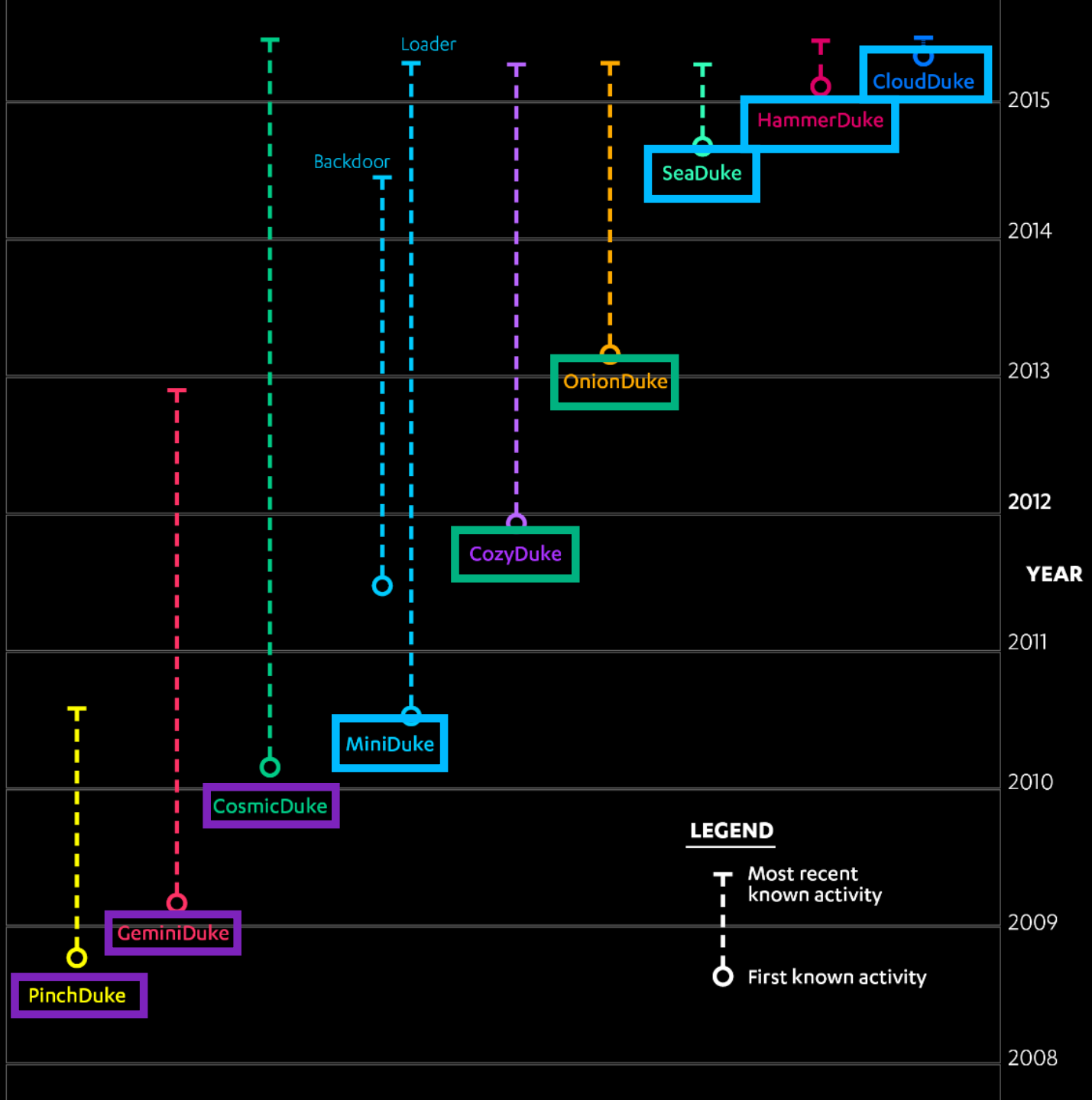
PinchDuke
CosmicDuke
GeminiDuke

“Modular toolsets”

CozyDuke
OnionDuke

“Backdoor toolsets”

MiniDuke
SeaDuke
CloudDuke
HammerDuke


Loader
Backdoor
CloudDuke
HammerDuke
SeaDuke
OnionDuke
CozyDuke
MiniDuke
CosmicDuke
GeminiDuke
PinchDuke
2015
2014
2013
2012
YEAR
2011
2010
2009
2008
LEGEND
Most recent known activity
First known activity

What makes them all “Dukes”?

Shared loaders

Shared implementation details

One drops another

Shared infrastructure

Tactics

Tactics

- Smash-and-grab
  - But if it's interesting, then switch tactics
- Interleaved with highly targeted attacks
- Stolen decoys
- 1days
- Malware only as a first stage
  - Steal credentials with malware/MimiKatz
  - Then use RDP, PowerShell, etc.

Infrastructure

- Fast churn
- Increasing use of direct IPs
- Increasing use of compromised servers
- Increasing use of SSL
- 3rd party services
  - Twitter as primary or backup C&C
  - OneDrive as primary or exfiltration C&C

Espionage?

Disclaimer:

Target $\not\Rightarrow$ victim

Targets of the Dukes

- Government ministries
  - Especially ministries of foreign affairs, ministries of defense
- Parliaments, senates, etc.
- Government "international cooperation" agencies, embassies
- Think tanks
- NATO
- Other government affiliated or associated organizations
- Other organizations involved with foreign policy

Targets of the Dukes

- Europe
  - Especially Eastern Europe
- Central Asia, Caucasus, Turkey, Georgia
- Asia, Africa
- Americas

April 5th 2009

Remarks By President Barack Obama In Prague As Delivered

THE WHITE HOUSE
Office of the Press Secretary

FOR IMMEDIATE RELEASE April 5, 2009

our allies. The Czech Republic and Poland have been courageous in agreeing to host a defense against these missiles. As long as the threat from Iran persists, we will go forward with a missile defense system that is cost-effective and proven. (Applause.) If the Iranian

11 days later …

Poland

Czech Republic

US think tank

2014

Adobe Flash Player 9
File
View
Control
Help

July 2014: CozyDuke

February 2015: CozyDuke

July 2015: CloudDuke

CloudDuke
1st wave

Tweet

TRACKING MINIDIONIS: COZYCAR'S NEW RIDE IS RELATED TO SEADUKE

POSTED BY: Brandon Levene, Robert Falcone and Richard Wartell on July 14, 2015 2:42 PM

FILED IN: Cybersecurity, Malware, Threat Prevention, Unit 42
TAGGED: AutoFocus, CozyCar, CozyDuke, forkmeimfamous, JSON, MiniDionis, Seaduke, WildFire

EXECUTIVE SUMMARY

Unit 42 has uncovered a new campaign from the CozyDuke threat actors, aka CozyCar [1], leveraging malware that appears to be related to the Seaduke malware described earlier this week by Symantec. [2]

SECURELIST

THREATS ▾ CATEGORIES ▾ TAGS ▾ ENCYCL

Minidionis – one more APT with a usage of cloud drives

By Sergey Lozhkin on July 16, 2015. 9:12 am

CloudDuke
2nd wave

1st wave:
Spearphish > Downloader >Loader > Backdoor

2nd wave: Spearphish > Loader > Backdoor

TOP

12345678

LEFT

Embedded Font ABC 123

12345678

Four 4 Point
Six 6 Point
Eight 8 Point
Ten 10 Point
Twelve 12
Fourteen

X

US LETTER FAX TEST PAGE

X

Four 4 Point
Six 6 Point
Eight 8 Point
Ten 10 Point
Twelve 12
Fourteen

12345678

© 2009 by FaxLogic, LLC

RIGHT

BOTTOM

12345678

Attribution

State-sponsored?

- Consistent targeting of entities relevant to foreign policy and security policy
  - Main benefactor is a government
- Continuation of operations rather than going unnoticed
  - Mission continuity is essential
- Apparent high level of coordination in operations
  - Organized group
- No fear of repercussions
  - They have protection

Operating within or directly for a government

Which government?

- Russian language artifacts
- Artifacts suggesting adherence to Moscow Standard Time TZ
- Compilation timestamps suggest majority of work during normal work days in Moscow Standard Time timezone
- Known targets align with Russian interests (among others)

Takeaways

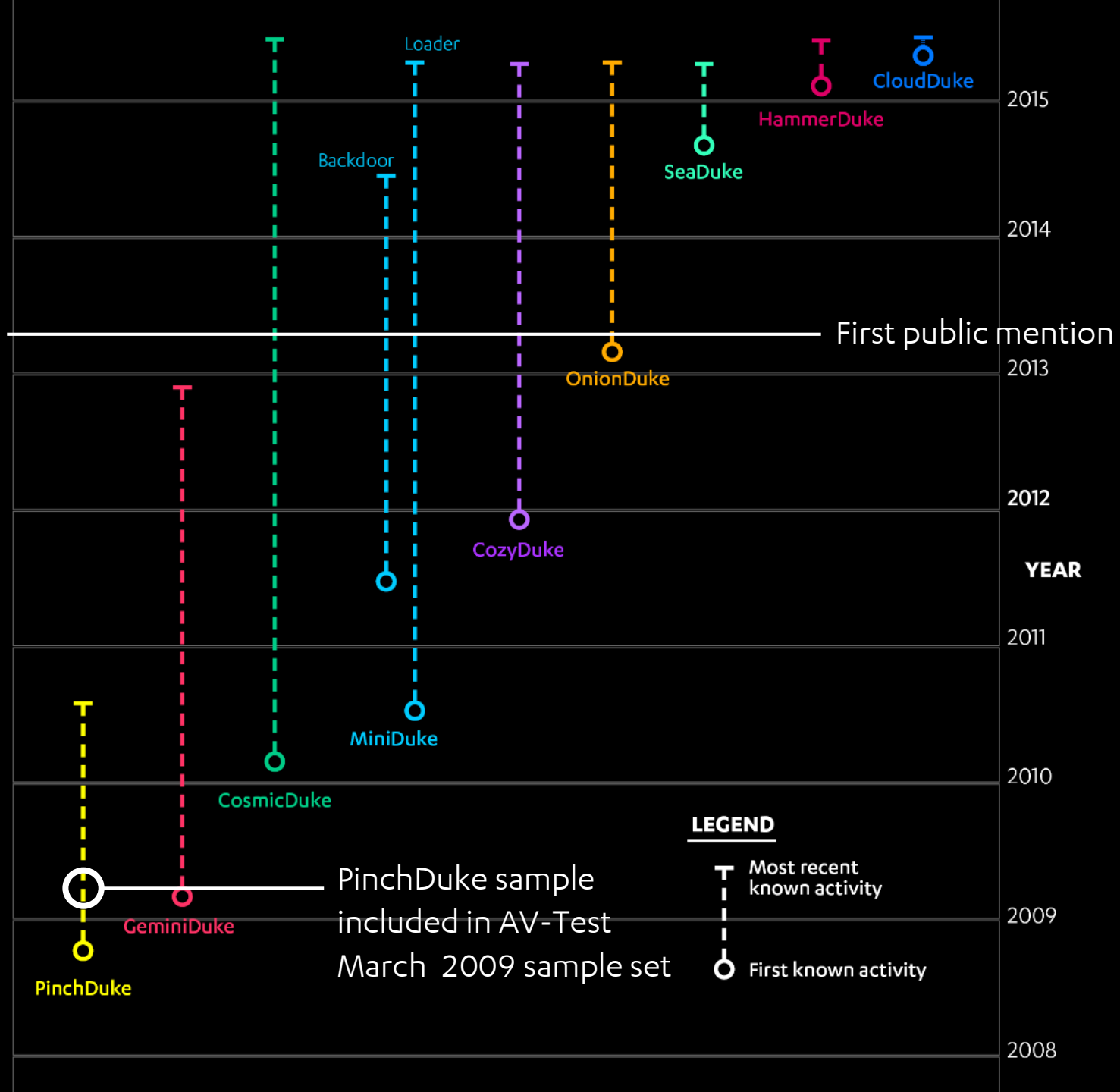
Think of “The Dukes”

Not “MiniDuke”
OR
“CosmicDuke”
OR
…

If you see one, look for others

But don’t just look for malware

Don’t rely on the network level


Loader
CloudDuke
HammerDuke
Backdoor
SeaDuke
2015
2014
First public mention
OnionDuke
2013
2012
CozyDuke
YEAR
2011
MiniDuke
2010
CosmicDuke
LEGEND
Most recent known activity
PinchDuke sample included in AV-Test March 2009 sample set
GeminiDuke
2009
PinchDuke
First known activity
2008

THE DUKES

7 years of Russian cyberespionage

https://www.f-secure.com/documents/996508/1030745/dukes_whitepaper.pdf

THE DUKES

7 years of Russian cyberespionage

@lehtior2